

Misir — Data Privacy Compliance Report (EU/EEA · USA · Bangladesh)

Date: 2026-06-07 **Scope:** Pre-launch data-protection compliance gap analysis for going live in Bangladesh, the USA, and Europe (EU/EEA). **Method:** Multi-agent audit — mapped the app's real personal-data flows from code, researched current (2026) law per jurisdiction, assessed gaps + remediations, then adversarially verified and ran a completeness critic.

⚠️ **Not legal advice.** This is a code-grounded compliance gap analysis produced by an AI using current (2026) law. Before launch, have a qualified privacy lawyer / DPO sign off — especially on the contested points flagged below.

Verdict: 🛑 DO NOT LAUNCH AS-IS — critical exposure in all three markets

A multi-agent audit mapped **46 personal-data categories** and **47 gaps** (22 launch-blocking), then adversarially verified them. Launching today would be indefensible in the EU, the US, and Bangladesh simultaneously.

The root cause is the product design, not a few bugs

Misir's core mechanic — the extension capturing **full page text from every site + full AI-chat transcripts, on by default, with no consent** — means it:

- ingests **special-category data** (GDPR Art 9 / CCPA "Sensitive PI": health, religion, sexuality, and the *contents of communications*) at scale, with **no lawful basis**;
- sweeps in **third-party people's personal data** (anyone named in a page or someone else's chat) — for whom GDPR notice (Art 14) is impossible at this scale;
- **harvests third-party AI providers' auth tokens/cookies** to scrape transcripts — which is *also* a computer-misuse offense (US CFAA, Bangladesh Cyber Security Ordinance 2025), not just a privacy one;
- ships all of it to a **US-only stack** (Supabase, Groq, Clerk) with no transfer mechanism.

No amount of paperwork fixes this; the collection model itself has to change (capture only what the user explicitly selects, redact on-device, drop the credential harvesting).

Current law in the three markets (2026) — key facts

Market	Status & what bites you	Max exposure
EU/EEA	GDPR applies extraterritorially (Art 3(2) — you offer services to + monitor EU users). EU-US DPF is still valid in 2026 (upheld <i>Latombe</i> , Sept 2025) but under appeal to the CJEU → "Schrems III" risk . ePrivacy Art 5(3) governs the extension touching the device. EU AI Act Art 50 transparency.	€20M or 4% of global turnover

Market	Status & what bites you	Max exposure
USA	No federal law, but ~20 state laws in force ; CCPA/CPRA + new CPPA regs effective Jan 1 2026 ; COPPA amended (full compliance Apr 22 2026); CIPA wiretap (all-party-consent states); and critically FTC Act §5 — the FTC's Avast case (banned selling browsing data, ~\$16.5M) is a <i>direct</i> precedent for this product.	Per-consumer fines × high volume; FTC consent decrees; class actions
Bangladesh	⚠️ Bangladesh now HAS a comprehensive law — the Personal Data Protection Ordinance (PDPO) 2025 (enacted Nov 2025, amended Jan/Feb 2026). It kept a cross-border transfer regime + residual data-localization , defines a "child" as under 18 , and applies extraterritorially. Cyber Security Ordinance 2025 criminalizes unauthorized access (your token harvesting). Enforcement body ramps to ~May 2027, but obligations apply now.	Turnover-based fines (2–5% for "significant" fiduciaries); imprisonment for fiduciaries was <i>removed</i> in the Jan 2026 amendment

Launch-blockers (P0) — the 22 critical gaps consolidate into 7 themes

#	Theme	Why it's illegal now	Core fix
1	No lawful basis / no consent for capture; default-ON	GDPR Art 6 + ePrivacy Art 5(3); CCPA notice + SPI; BD PDPO consent	Capture OFF by default ; affirmative, per-purpose, jurisdiction-aware consent before any collection (no pre-ticked boxes/dark patterns)
2	Special-category / Sensitive-PI captured at scale	GDPR Art 9 (highest-risk); CCPA SPI <i>incl. contents of communications</i> ; BD sensitive data	Stop capturing comms-contents (webmail/DMs/others' turns); on-device redaction of special-category data before anything leaves the browser
3	Third-party (non-user) data swept in	GDPR Art 6 + Art 14 (notice impossible at scale); BD; US	Data minimization + redaction; capture only user-selected content
4	Third-party AI credential harvesting / private-API scraping	CFAA (US); BD Cyber Security Ordinance; ePrivacy; Chrome Web Store	Remove the module entirely (chatgpt/claude/kimi adapters + inject-web.js fetch hook). Single most dangerous component.
5	No privacy policy / notice-at-collection / consent UI anywhere	CCPA §1798.100; GDPR Art 13/14; ePrivacy	Publish privacy policy + notice-at-collection in both app and extension; build consent flow
6	No DSAR / account deletion / export	GDPR Art 15/17/20; CCPA delete/know/correct; BD rights	DELETE /me (account + cascade), /me/export , access/correction; erasure

#	Theme	Why it's illegal now	Core fix
			fan-out to embeddings, caches, soft-deleted chats, and sub-processors
7	Unlawful cross-border transfers + no DPAs + US-only stack	GDPR Ch. V + Art 28; BD transfer/localization; CCPA service-provider	EU-region hosting; SCCs/DPF verification (Clerk is DPF-listed; Groq & Supabase are not → need SCCs + TIA); signed DPAs; BD localization assessment

Plus **Chrome Web Store**: `<all_urls>` default-on capture likely fails **Single Purpose + Limited Use + prominent-disclosure** rules → extension removal risk (the manifest `host_permissions` scoping already applied helps but isn't sufficient).

Important (P1)

- **Indefinite retention** — no TTLs/purge anywhere → add retention lifecycle + published periods (GDPR 5(1)(e); CCPA; BD).
- **Governance pack** — **DPIA is legally mandatory** here (large-scale Art 9 + systematic monitoring) *before* processing; plus RoPA (Art 30), a **DPO** (Art 37), an **EU Art 27 representative**, a breach runbook, and **audit/access logging** (today you couldn't detect or scope a breach — there's no access log).
- **Children** — no age assurance; `<all_urls>` capture can ingest minors' data → COPPA / GDPR Art 8 / PDPO under-18.
- **Security-as-privacy** — RLS off + single service-role key (verifier *downgraded* this to Medium since app-layer scoping exists, but enabling RLS + per-user policies is still recommended).

Don't over-react — verified false positives & corrections

The adversarial pass caught overstatements; **skip these** so you don't waste legal spend:

- **EU AI Act "emotion-recognition" ban** — applies only to **workplace/education**, not a consumer app. (Art 50 transparency may still apply.) ❌ not a prohibition for you.
- **Data-broker registration** (CA Delete Act/TX/OR) — **not triggered**; you have a direct relationship with users.
- **CIPA "wiretap"** — real but **legally contested** → treat as High, not Critical.
- **"No DPAs executed"** — can't be proven from code; Clerk/Supabase/Groq all *offer* DPAs — **verify out-of-band**, don't assume.
- **"Embeddings/synthesis survive deletion"** — inaccurate: `DELETE /artifacts/{id}` already deletes them. The real gap is *account-level* deletion + caches + soft-deleted chats.
- `GET_COOKIE` is already hardened to a `kiml-auth` allowlist (earlier security fix) — but the harvesting design still must go.

Core solution path

Strategic (unavoidable): pivot from "capture everything passively" to **"capture only what the user explicitly selects, redacted on-device,"** and **delete the third-party credential-harvesting module**. Everything else is downstream of that.

Then the implementable checklist:

1. Consent gating + capture-off-by-default (extension + backend gate)
2. Account-deletion + data-export (DSAR) endpoints with erasure fan-out
3. Retention TTLs + scheduled purge
4. Region/residency config (EU hosting) + transfer documentation
5. Privacy-policy / notice / "Do Not Sell/Share" + GPC honoring (the extension must honor GPC since it's the collector)
6. Age-gate + child-directed-context exclusion
7. RLS + per-user policies + audit logging
8. On-device special-category/PII redaction before upload

Operational/legal (you + counsel): DPIA, RoPA, DPO, EU Art 27 representative, signed DPAs, breach runbook.

Recommended next step

The highest-leverage move is the **consent + capture-off-by-default + DSAR/account-deletion + retention** layer, since those are concrete code changes that unblock several P0/P1 items at once. The DPIA + RoPA documentation drafts can proceed in parallel with counsel.

Generated by an AI compliance audit. Persisted project memory: [privacy-compliance.md](#). Related internal notes: [security-posture.md](#), [data-model.md](#), [extension-architecture.md](#).